CYBER SECURITY REVIEW

“Understanding Phishing: How Attacks Trick Users and Threaten Cybersecurity “

Group 10

Names: Mufid Fata Rifki
Haikal Raihan Hafidz
Reyandanu Fajri Daniswara

Class: 2CS2

CEP CCIT

FAKULTAS TEKNIK UNIVERSITAS INDONESIA

2025

PREFACE

First of all, thanks to Allah SWT, who has given us the opportunity to complete this task. Blessing and salutation may also be upon the most honorable prophet Muhammad SAW who has given us life guidance from our birth to the end of life

The title of this paper is “Understanding Phishing: How Attacks Trick Users and Threaten Cybersecurity” and submit it as Cyber Security Review task requirements. Our purpose in creating this report is to get to know the Phishing process, starting from how they plan it to execute it.

Depok, 5th February 2025

Authors

TABLE OF CONTENTS

PREFACE **2**
TABLE OF CONTENTS **3**
TABLE OF FIGURES **4**
CHAPTER I **5**
INTRODUCTION **5**
I.1 Background 5
I.2 Writing Objectives 5
I.3 Problem Domain 5
I.4 Writing Methodology 6
I.5 Writing Framework 6
CHAPTER II **8**
BASIC THEORY **8**
II.1 Definition of Phishing 8
II.2 Types of Phishing 8
CHAPTER III **15**
PROBLEM ANALYSIS **15**
III.1 Problem to be Resolved 15
III.2 Detecting and Preventing Phishing Attacks 15
III.3 Phishing Growth Over Time 17
III.4 Human Weaknesses and Defenses in Phishing 17
III.5 Are Current Anti-Phishing Measures Truly Effective 17
III.6 Phishing Continues to Evolve as a Continuous Threat Despite Advanced Security Measures 18
III.7 Top three countries hosting phishing attacks 18
III.8 Top three countries most affected by phishing attacks 20
III.9 Top three countries least affected by phishing malware 21
III.10 Top three countries most targeted industry sectors in phishing 23
III.11 Top three malware used for phishing 24
CHAPTER IV **26**
CONCLUSION AND SUGGESTION **26**
IV.1 Conclusion 26
IV.2 Suggestion 26
BIBLIOGRAPHY **27**

TABLE OF FIGURES

Figure 1 Top 4 countries hosting phishing attacks
Figure 2 Trend analysis on countries hosting phishing
Figure 3 Top 3 countries affected by phishing
Figure 4 Trend analysis on the top 3 countries that are affected through phishing
Figure 5 Least phishing malware affected countries
Figure 6 Trend analysis on the less phishing malware affected countries
Figure 7 Top 3 most targeted industry sector by the phisher
Figure 8 Trend analysis on most targeted industry sector
Figure 9 Type of the malware used for phishing
Figure 10 Trend analysis of top three malwar

CHAPTER I

INTRODUCTION

I.1 Background

In this modern world, we know that technology has been improving year by year. The cause of this improvement makes the technology also vulnerable. As we know, in this world there will always be two types of people, the good one and the bad one. The bad guy will also improve their way of attacking the new technology.

and in this research we will explain a method of attack carried out by bad people, namely Phishing, which is taken from the word fishing. Phishing is a type of security threat that lootes user's personal info such as, credit card info, ID info, ATM pins, and etc.

So what are the solutions to this problem?. That's why we made this research to give the full in depth information about Phishing. starting from what Phishing itself is, how does phishing work, what types or methods hackers use, and how to prevent these attacks

I.2 Writing Objectives

This report was created with the intention of offering information and understanding of Phishing The workings of phishing and its countermeasures..

I.3 Problem Domain

In the modern era phishing attacks are improving, and with the use of artificial intelligence (AI) and machine learning (ML) to scam victims more advanced. This paper mainly explains about phishing attacks from social engineering, website based, search engine based, and also malware phishing based such as,host based, DNS based, server based.

In this Cybersecurity review research paper, it focused on Phishing attacks. From the general and definition of phishing, various types, top 3 countries with affected and least affected by phishing,and ways to prevent it. These are the main topics of our journal review

The issues the author discussed in this Cyber Security Review are as follows:

1. Definition of Phishing
2. Types of Phishing
3. Top countries affected and least affected
4. mitigation

I.4 Writing Methodology

Our writing method is descriptive analysis. Data research techniques such as descriptive analysis help in the description, illustration, or summarization of information points, allowing the development of patterns that fulfill all the requirements of the data. through online resources and user feedback

I.5 Writing Framework

The writing framework for this paper will consist of four chapters, starting with the introduction of this research paper. And then we'll dive into the basic theory, and then we'll explain about further details of the subject. And then finishing off with a conclusion and suggestion.

Chapter I: Introduction

This chapter contains background, writing objectives, problem domain, writing methodology, and writing framework

Chapter II: Basic Theory

This chapter will explain more about the general things about Phishing itself

Chapter III: Problem Analysis

In this chapter, the explanation of Phishing will be more in-depth by presenting all the details

Chapter IV: Conclusion and Suggestion

This chapter contains conclusions and suggestions regarding the research we are conducting and observe

CHAPTER II

BASIC THEORY

II.1 Definition of Phishing

In today's digital landscape, phishing remains a significant cybersecurity challenge where attackers attempt to steal (SPII) sensitive personal identifiable information, including online banking credentials, credit card details, CVV numbers, and ATM PINs. These scams typically involve deceptive communications, such as fraudulent emails and messages, containing links to counterfeit websites designed to harvest confidential data. Financial service users, particularly those engaged in electronic banking, are primary targets for these attacks.

The word "phishing" comes from "fishing" because they work in a similar way. Just like how fishermen use bait to catch fish, scammers use fake emails with harmful links to trap internet users and steal their passwords and personal information. The name is also linked to "phreaks" - people who used to break into phone systems to make free calls or listen in on phone lines. That's why it's spelled with "ph" instead of "f" - to show its connection to these phone hackers.

In the past 20 years, phishing has become one of the most dangerous types of online attacks, happening many times every day. The first known phishing scam happened on January 2, 1996, targeting AOL, which was a popular internet company at the time.

II.2 Types of Phishing

Phishing attacks come in various forms, each designed to trick individuals or exploit weaknesses in computer systems and networks. Some phishing methods rely on deceptive messages or websites, while others use malware or manipulate internet settings to steal sensitive information. Below is an overview of the main types of phishing attacks and how they operate.

1. **Social Engineering-Based Phishing**
   a. **Message Based**

      This type of phishing is delivered through messages and can be categorized into four main types, which we'll explain below in detail:

I. Deceptive phishing/link manipulation

Deceptive phishing occurs when attackers send emails with links to fake websites that appear to be from trusted sources such as banks, e-commerce sites, or social media platforms. These emails often create a sense of urgency to persuade users to click on the link and enter their login details.

Link manipulation is a related tactic where attackers design a fake web address that looks like a legitimate one by including familiar names in the subdomain. Users who click the link are directed to a fraudulent site, where they unknowingly provide their credentials to attackers.

II. Spear phishing

Spear phishing is a more targeted attack, where cybercriminals send emails that appear to be from a trusted individual, such as a colleague or manager. To make the attack convincing, the attacker may first compromise an employee's email account using malware. The attacker then sends fake emails to others in the organization, often containing links to malicious websites or attachments that install malware on the recipient's device.

III. Phone phishing (Vishing)

Vishing, or voice phishing, involves attackers using phone calls or text messages to deceive victims into revealing personal information. They often use caller ID spoofing and automated voice systems to pose as legitimate organizations. Common vishing scams include fake warnings about unauthorized credit card transactions, urging victims to call a number where they are tricked into providing sensitive details.

IV. Social media phishing

Social media platforms like Facebook, Twitter, and Instagram have become popular tools for phishing. Attackers exploit these platforms to trick users into clicking malicious links or sharing personal information.

Common methods include using fake profiles, compromised accounts, and bot-generated messages to spread phishing attacks.

b. Website Based

Phishing through websites primarily occurs via advertisements and tabnabbing. Cybercriminals exploit online advertising to create fake websites that appear in search engine results. Instead of sending phishing emails, they pay for ads that link to fraudulent websites. Users who click on these ads, often appearing at the top of search results, may unknowingly enter their login credentials on a fake site.

Tabnabbing, on the other hand, occurs when a malicious website changes its appearance while open in an inactive browser tab. When the user returns to the tab, they may not notice that it has changed to a fake login page, where they unknowingly enter their credentials.

c. Search engine based

Search engine-based phishing happens when attackers register domain names similar to real websites. These deceptive links appear in search results, leading users to fraudulent sites that steal their information. This technique shares similarities with typosquatting, another method attackers use to deceive users. However, instead of relying on search engines, typosquatting targets users who manually enter URLs or misspell website names.

Typosquatting takes advantage of common spelling mistakes when typing URLs or search terms. Attackers register domains with slight variations of well-known websites, making it easy for users to land on a phishing page without realizing it. For example, "amazn.com" instead of "amazon.com."

2. Malware-Based Phishing

Malware-based phishing involves installing malicious software on a victim's computer to steal personal information. This can happen through email attachments, fake downloads, or exploiting software vulnerabilities. Small and medium-sized businesses (SMEs) are often targeted due to weaker security measures. Bellow is three level of malware-based phishing:

a. Host Based

Phishing at the host level involves various techniques such as installing keyloggers, modifying host file records, and carrying out system reconfiguration attacks. These attacks are executed by injecting malware into the victim's system. Among the different types of malware used for host-level phishing, botnets and Trojans are the most common. The detailed explanation of host-level phishing attacks is provided below:

I. Keylogger

Keyloggers are spyware programs that record keystrokes, allowing attackers to capture sensitive information like login credentials. They can be software-based, installed on a device, or hardware-based, attached between the keyboard and computer.

II. Host file poisoning

Host file poisoning occurs when a Trojan virus modifies a computer's host file to redirect users to fraudulent websites instead of legitimate ones.

III. Browser proxy configuration attack

These attacks alter a victim's browser settings to route traffic through a fake proxy server controlled by the attacker. A common example is DNS rebinding, where malicious JavaScript bypasses security measures to steal data.

IV. System reconfiguration attacks

Attackers gain access to a victim's device and modify settings like bookmarked URLs, replacing them with phishing sites that look authentic.

b. DNS Based

I. DNS hijacking

DNS hijacking is when an attacker changes a computer's DNS settings to redirect users to malicious websites. This is usually done by installing malware on the victim's system. Attackers can hijack DNS settings in different ways, such as:

- Domain hijacking: Stealing control of a website's domain by hacking the registered email.
- Router hijacking: Changing home router settings to redirect users to fake sites.
- Rogue DHCP: Tricking a device into using a fake network server to control internet traffic.
- DNS tunneling: Hiding malicious data inside DNS queries to steal information.

II. DNS spoofing

DNS spoofing is another technique where attackers insert false DNS data, making users visit fake websites without knowing. Some common DNS spoofing methods include:

- Cache poisoning: Corrupting a DNS server's memory to redirect traffic.
- DNS ID spoofing: Intercepting and faking DNS responses.
- Botnet attacks: Using networks of infected devices to spread phishing scams.
- Fast flux: Constantly changing IP addresses to make phishing harder to detect.

- Dynamic Pharming: Tricking users into accepting fake security certificates, allowing attackers to steal login details.

c. Server Based

There are three types of phishing attacks that can be performed on the server side:

I. Search Engine phishing/page rank escalation

Attackers manipulate search engine rankings to make phishing sites appear at the top of results. These sites may offer fake discounts or job opportunities to lure victims into entering their credentials.

II. Content injection

In this attack, hackers insert fraudulent content into a legitimate website, such as fake login forms or malicious downloads that install malware.

III. Zero-day attack

Zero-day attacks exploit unknown software vulnerabilities before developers release security patches. Hackers use these weaknesses to install malware and steal data.

3. User Information Control (Ransomware)

a. Lock screen ransomware

In Lock screen ransomware, the phisher displays an alert screen and warns the user that his system is locked and demands a ransom to unlock the screen.

b. Crypto ransomware

In Crypto ransomware, the phisher encrypts the file in the PC so that the user cannot open those files without the key. Any files can be encrypted by using ransomware. Only the attacker can decrypt the file with his/her private key. There is no guarantee that the user will get the key after paying the ransom in the form of bitcoin (BTC)).

c. WannaCry ransomware

WannaCry ransomware is a ransomware attack that infects the windows operating system. It encrypts the entire hard disk of a computer and stops the user from accessing the system and demands some ransom in the form of Bitcoins to decrypt the data. This ransomware can spread either through phishing email attachments or through hacking tools.

CHAPTER III

PROBLEM ANALYSIS

III.1 Problem to be Resolved

Based on the journal we are addressing and study of the phishing attacks, that has been explained in this paper:

1. Phishing scams on SNS are increasing drastically.
2. Attackers can get their victim's unauthorized access by spreading fake news, malicious URLs & attachments. Usually, the attackers use a bot account that is an automated codes that is performing the attack without any human interaction
3. Identifying a scam in SNS is way more complicated compared to other phishing attacks. First thing we must do to identify a scam in SNS is to see whether the URL is phishing or not. And then, we have to know if its phishing or legitimate. Attacker, usually develops a look-alike domains or even look exactly same as some popular companies/organizations to fool the victims to click their faked links to gather either PII (Personal Identifiable Information) or SPII (Sensitive Personal Identifiable Information)
4. One of the approaches to do phishing detection is Machine learning-based. The main challenge in machine learning is improving model performance while using fewer features. It's important to find the smallest set of features that still boosts the model's accuracy.
5. Since malware-based phishing attacks install and work in the background without even the user's knowledge it is harder to detect the attacks.

III.2 Detecting and Preventing Phishing Attacks

We must live with either the potential of being scammed or we only can hope that solutions will do their jobs to totally protect us from getting scammed. For example, during the middle age of covid popular brands such as Google, LinkedIn, Amazon etc. are very common to get impersonated or being spoofed. Those platforms are some examples that people use for their day-to-day activity.

With that in mind, we as the contributors of the Internet world really have to be well-informed and be trained as it's the best defense against phishing. People who were exposed to phishing emails more frequently were better at identifying them correctly compared to those who encountered them less often. Essentially, more experience with phishing emails improved their ability to detect them, likely because repeated exposure helped them recognize patterns and warning signs. Participants who have been a part of training were better able to detect and avoid the phishing attack. Also, Participants who like to play an online game were able to detect spoofed links or fraudulent webs.

There are 3 main aspects that we need to know what are the most used aspects from the attacker. Such as OTP, desktop barrier applications, and behaviour modification. These 3 aspects will improve our way to know which is phishing which is not.

I. OTP

One time password is a commonly used method for securing online systems. An OTP is a short term password that is generated as needed and it'll expirate when it is used. Its usually a random combination of numbers and letters.

An OTP will appear when someone is trying to log in to an account. And the one that has it is the main account. The OTP will appear through SMS message as the authentication step. Where attackers usually target username, and password account. When the OTP is incorrect the login process will be canceled.

II. Desktop Barrier Applications

Kaur and Kalra propose a five-level desktop barrier application designed to prevent users from opening suspicious webpages. Phishers are motivated by recognition, monetary gain, or identity improvements. Multi-level desktop barrier applications can detect these motivations as weaknesses. This aids in preventing the phishing attempts from being successful.

III. Behaviour Modifications

Miller Bryon address, In addition to relying on the software-based strategies described above, users must be educated to recognize potential phishing attacks. The most common and widely accepted method for reducing the success rate of phishing attempts is behavior modification. This can be challenging, because behaviors can be very difficult to change. This behaviour will improve the way of detecting any suspicious link, especially phishing. From websites, even from email messages.

III.3 Phishing Growth Over Time

The first phishing scam first occurred on 2nd January 1996 on American Online or as called AOL. Credit Numbers were randomly generated for the phisher to create AOL accounts. The Phisher sends the email to the victims asking them to verify their account details by clicking a link inside the email. If the victims click the link it will automatically transfer the information the phisher wanted. The phisher will use that information for crime activities.

In this day and age, Phishers are now becoming more capable at making websites look exactly like the official pages in order to make them more convincing. As times change, phishers intend to persuade their victims. Phisher persuades internet users to click on a suspicious link which contains fake news, controversial videos, and other persuading techniques.

III.4 Human Weaknesses and Defenses in Phishing

Social engineering is a psychological manipulation of people into Revealing sensitive information. The attacker always targets the humans or the users since users are the most vulnerable aspect of the security system. One very example for social engineering is through email. The phisher sends an email with a link that looks very similar to the original one but it redirects the users to a spoofed site to steal their information.

Stanford University and Tessian have studied that one in four employees or around 25% of the employees said they have clicked on a phishing email at work. Men compared to women are easier to fall for phishing scams, older employees were the least likely to be affected.

III.5 Are Current Anti-Phishing Measures Truly Effective

To protect users from phishing attacks, numerous researchers and organizations have developed various anti-phishing tools. Most of these tools operate on the user end, while only a few function on the server side. Although there are so many existing anti-phishing systems, phishing continues unceasingly due to inadequate detection of unknown vulnerabilities, excessive computational overhead, and high false positive rates.

Accordingly, participants were attentive to spelling errors in older phishing emails, requests for sensitive information, and any subtle deviations from the usual email format they were accustomed to. Singh et al. studied people's success on the detection of phishing emails and found that participants receiving a higher frequency of phishing emails had a higher hit rate compared to participants encountering lower frequency levels during training.

III.6 Phishing Continues to Evolve as a Continuous Threat Despite Advanced Security Measures

Phishers have improved their ability to create fake websites that closely resemble legitimate ones, often incorporating official logos and well-designed layouts to make them appear more trustworthy. In addition, phishing emails have become more sophisticated, making it harder for users to distinguish between real and fraudulent messages. While phishing attacks have existed for decades, they have evolved significantly, now using advanced social engineering techniques to manipulate victims. The growing reliance on digital communication, especially after the COVID-19 pandemic, has further increased the success of phishing scams, making them a serious cybersecurity threat.

III.7 Top three countries hosting phishing attacks

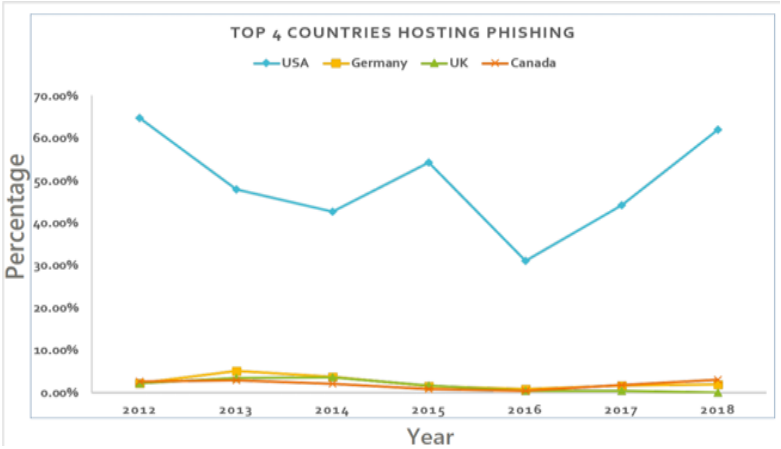


Figure 1 Top 4 countries hosting phishing attacks

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)

Figure 2 Trend analysis on countries hosting phishing

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)

From the analysis that S. Chanti and T. Chithralekha did in their journal, they found that the United States, Germany, and United Kingdom (UK) are the top three countries hosting phishing scams and have appeared in the maximum number of quarters as shown in *Figure 1*. Among these countries, the USA stood at the top every year with an average of 49% of phishing scams followed by Germany (2.40%) and UK (1.66%). *Figure 2* shows the trend analysis and pattern observed in the top countries hosting phishing scams.

III.8 Top three countries most affected by phishing attacks

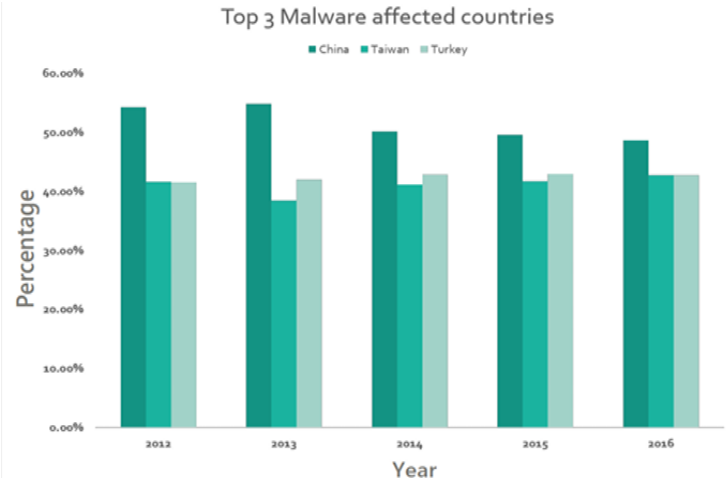


Figure 3 Top 3 countries affected by phishing

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)

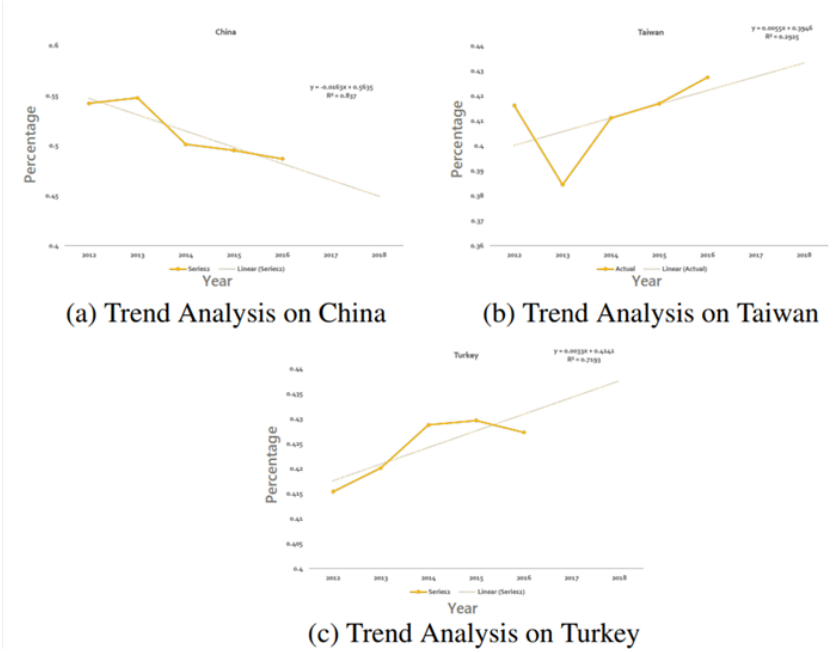


Figure 4 Trend analysis on the top 3 countries that are affected through phishing

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)

As S. Chanti and T. Chithralekha mentioned in their Journal, from *Figure 3* it is so obvious that China is a top phishing attack affected country with an average of 51.46%, followed by Turkey with 42% and Taiwan with 41.11%. Although China is the top country affected by phishing, as shown in *Figure 4 (a)*, the R^2 Value (83%) is high, and it follows a decreasing trend. That means

the percentage of phishing is decreasing year by year. If the phishing affected rate is decreasing, it might be due to better security measures. In the case of Turkey and Taiwan, they follow an increasing trend as shown in *Figure 4 (b)* and *4 (c)*. Compared to China, Turkey and Taiwan are less affected, but they are following an increasing trend over the years.

III.9 Top three countries least affected by phishing malware

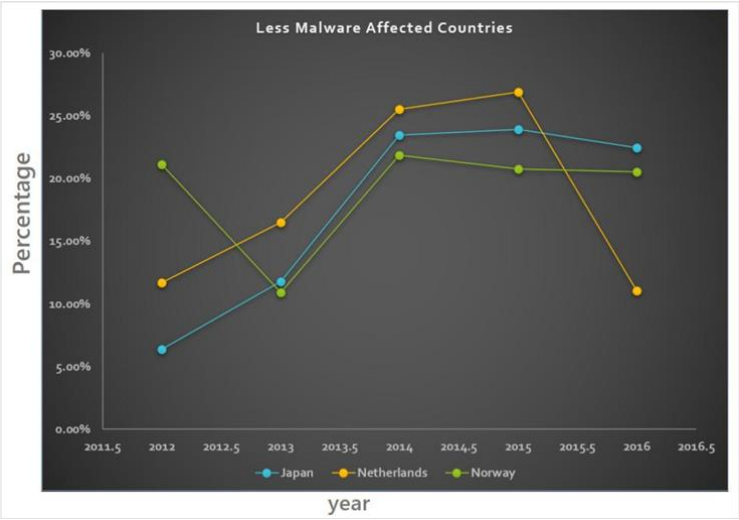
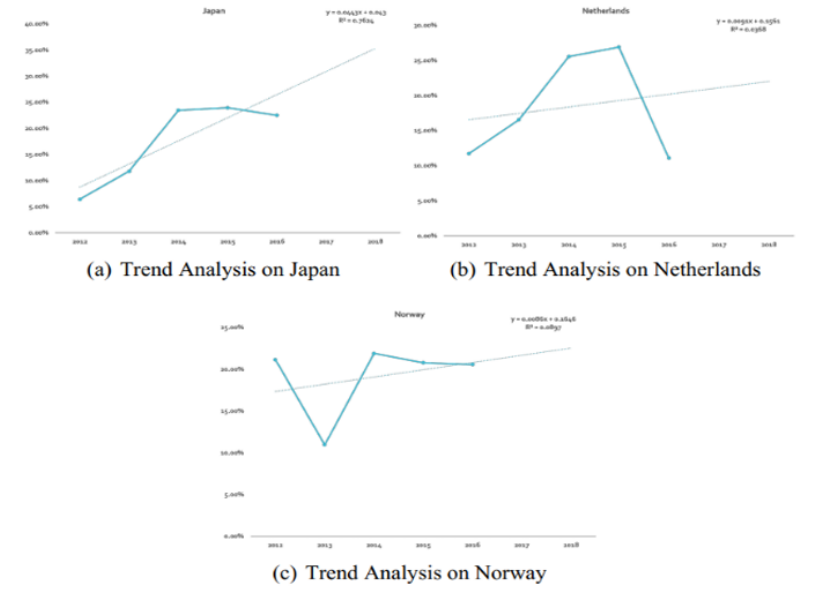


Figure 5 Least phishing malware affected countries

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)



(a) Trend Analysis on Japan

(b) Trend Analysis on Netherlands

(c) Trend Analysis on Norway

Figure 6 Trend analysis on the less phishing malware affected countries

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)

As S. Chanti and T. Chithralekha mentioned in their Journal, Japan is the least affected country with an overall average of 17.59%, followed by the Netherlands and Norway with 18.34% and 20.55% respectively. *Figure 6 (a)* shows the trend analysis of Japan, which follows an increasing trend with an R^2 value of 76%. Even though Japan is the least affected county, the percentage of phishing affected rate is in- creasing year by year. In the case of Norway and the Netherlands, they follow an increasing trend with R^2 value as 3% and 8%, respectively. Due to the low R^2 value, the prediction may not be accurate, and the phishing affected rate varies a lot in both countries every year.

III.10 Top three countries most targeted industry sectors in phishing

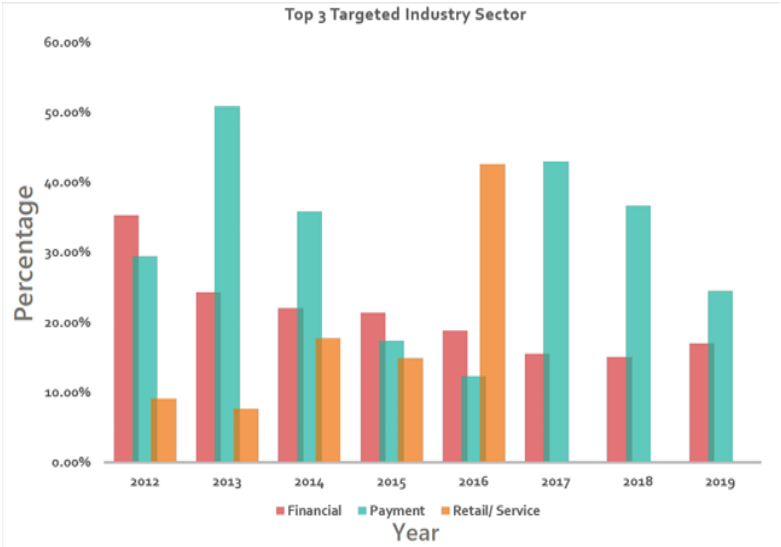
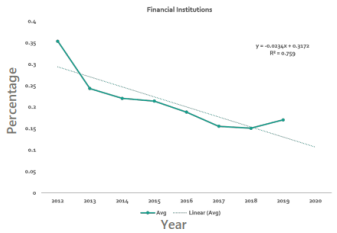


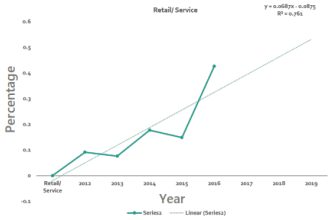
Figure 7 Top 3 most targeted industry sector by the phisher

(REF : Chanti.S and Chithralekha.T, *A literature review on classification of phishing attacks.*)



(a) Trend Analysis on Financial Institutions

(b) Trend Analysis on Payment Systems



(c) Trend Analysis on Retail/Service Sector

Figure 8 Trend analysis on most targeted industry sector

(**REF : Chanti.S and Chithralekha.T,** ***A literature review on classification of phishing attacks.***)

As S. Chanti and T. Chithralekha mentioned in their Journal, From *Figure 7*, it is found that the payment system, financial, and retail/service sectors are the most targeted industry sectors. The payment system is the most targeted industry sector compared to the financial and retail/service sectors. However, when we observe year-wise, the payment sector is affected a lot between 2013-2019, the financial sector was highly affected in 2012, and the retail/service sector was highly affected in 2016. When these countries are observed individually as shown in *Figure 8*, the financial sector follows a decreasing trend with a high R^2 value (i.e.,75%), payment sector follows an increasing trend with a low R^2 value (i.e., 5%), and retail/service sector is observed to have an increasing trend with high R^2 value(i.e.,76%). In the financial and retail/service sectors, the R^2 value is greater than 50%, which gives better forecasting and the model fits the data. But, in the case of the payment sector, the R^2 value is less than 50% (i.e., 5.27%) which means the model does not fit the data.

III.11 Top three malware used for phishing

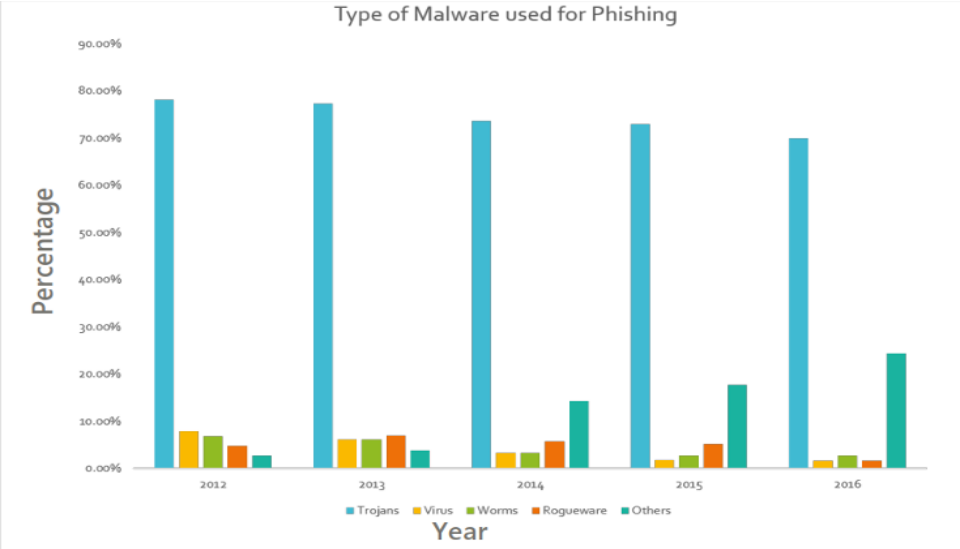


Figure 9 Type of the malware used for phishing

(**REF : Chanti.S and Chithralekha.T,** ***A literature review on classification of phishing attacks.***)

(a) Trend Analysis on Trojans (b) Trend Analysis on Virus

(c) Trend Analysis on Worms

Figure 10 Trend analysis of top three malware

(**REF : Chanti.S and Chithralekha.T,** ***A literature review on classification of phishing attacks.***)

As S. Chanti and T. Chithralekha mentioned in their Journal, Trojans, virus, and worms are the top three most commonly used malware for phishing from the analysis. *Figure 9* shows the impact of malware over the years. The Trojan is at the top among this malware almost every year, followed by a virus, and worms. When this malware is observed individually by plotting a trend line, an interesting thing is observed: all the malware follows a decreasing trend. *Figure 10* shows the pattern and type of trend followed by each malware. For Trojans, Virus, and worms, the R^2 values are 95%, 92%, and 86%, respectively, which gives an accurate prediction

CHAPTER IV

CONCLUSION AND SUGGESTION

IV.1 Conclusion

The conclusion of the research paper we made about Phishing is to open up more insight and attention to the information we have and store. Because this phishing method is more likely to use our mentality in getting caught up in the attack. This report explains from definitions, types,prevention, etc.

As we know that this Phishing attack is always evolving, that's why we need to be more cautious when we're on the internet, especially any suspicious link that is directed to the unknown or illegal sites. Always take care your own credential, especially financial

IV.2 Suggestion

Our suggestion as an author to the reader is, always pay attention to any suspicious link, and sender. Because there's always bad people who try to get our private information, especially our financial information.

And if you want to explore more about phishing and its related things. You can search any Journal, Research paper, news, and youtube videos. Such as Scopus Journal, IEEE journal, any journal that has an international standard. To explore more about phishing, focus on prevention. With that information we can identify which is phishing which is not.

BIBLIOGRAPHY

[1] Chanti.S and Chithralekha.T 2022. *A literature review on classification of phishing attacks.* International Journal of Advanced Technology and Engineering Exploration

[2] Carroll Fiona, Adejobi John Ayooluwa, Montasari Reza. 2022. *How Good Are We at Detecting a Phishing Attack? Investigating the Evolving Phishing Attack Email and Why It Continues to Successfully Deceive Society.*

[3] Miller Bryon et al. 2020. *Prevention of Phishing Attacks : A Three Pillared Approach.*